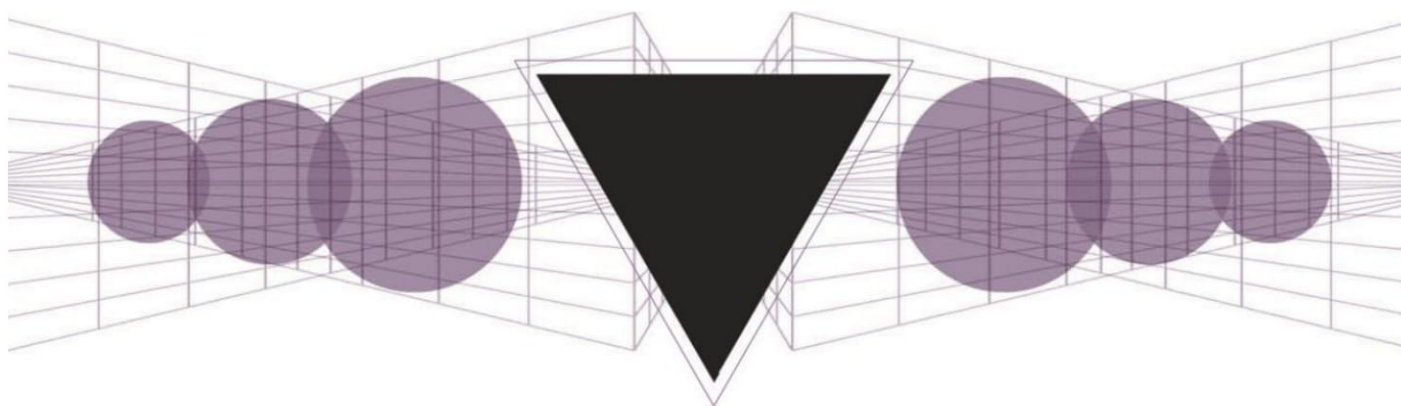




哈尔滨工业大学

网络空间安全专业

考研笔记整理

《信息安全导论》基础部分

By : GuoJohnny

Mail : guojohnny@guojohnny.cn

Github: <https://github.com/guoJohnny/-837->

前言

终于开始着手整理自己考研期间的笔记了。重新翻看自己这一年的汇总的错题总结，难免有些感慨。这笔记里面的题目来源已经记不清了，有的来自网络上搜集的各大院校的资料，有的是教材课后习题，有的是其他相关书籍的课后题目，甚至有一些是我自己给自己出的题（出题水平很低，只是为了差缺补漏）

这么做是因为选择了考哈工大 837 专业课，就要面临着没有本校考研试卷，没有太多资料总结，没有人员辅导的尴尬处境。看过 837 考纲的同学就能发现，考试的知识点是比较宽泛的，没有一些细节考点例子。我能做的只有把教材的每一个细节整理出来，我不清楚这样的整理对我成绩的提高有多大，但是面对这样的情况这种做法是唯一的选择。

我深知缺乏考研资料对于考研的学生来说是多么难受的一件事情。作为一个经历过搜集资料的人来说，不希望别人重复这样一个花费时间的过程，也不希望有人将这些资料作为获利来源。在我看来，你能用这些资料提升到什么程度是你自己的个人能力，但是这些知识和资料本就该作为一种共享资源开放给需要的人。

我在动笔写笔记整理前有在想，这篇笔记应该整理成怎么样才是个合格的笔记？如果单纯地将我自己专业课笔记逐字逐句敲成文字，那这个笔记的作用是否还存在呢？因为笔记上的题目大多来自各种题库、院校试卷，单纯敲下题目和答案上传，无非又是一个题库，对考研的后来者的帮助又有多大呢？

作为本科信息安全毕业，并且在信息安全行业多 2 年多的人来说，这份笔记更应该增加一些考试之后的总结，结合从业经验和考试重点来思考这些题目的意义，更多的是在原有笔记的基础上增加对出题人出题角度的思考。

由于当初备考总结的时候是按照错题进行记录的，实在无心力将这些题目按知识点归纳整理，只能在每道题目之后增加个人对这道题目的理解。造成的使用不便请见谅。

1、信息安全三要素是（ ）、（ ）和（ ）。

答：CIA 三元组，即机密性、完整性、可用性

【注：这道题目是最基础的题目，相信每个人都能很好掌握这个知识点。但是如果作为出题人，既想考察你这个知识点，又不想过于简单失去区分度。出题人可能从英文角度出发，考察你相应知识的英文。例如 2019 年 837 专业课选择题有一道：

信息安全三要素有 Confidentiality、Integrity，请问另外一个：

A、Authorization B、Authentication C、Availability D、Account

由于时间过长具体选项已经记不清了，但是大致题型如上题所述。在试卷上可能会出现相近的单词（甚至是错误的人造单词）让你选择。出题人目的是在考察学生们是否真正将知识点吃透，理解信息安全的基本要素和基本原则是围绕着 CIA 三元组展开，这三个字母分别的意思代表着什么？各自的作用是什么？什么是这三个目标的基础？而不是单纯只在记忆上下功夫，舍本逐末。

再者，考纲教材中出现了很多知识点的缩写，例如 DMZ，SA，AD，LSA 等等，是否可能出现类似的选择題，或者填空题？这就需要读者自己把握。

】

2、简答题：Unix 系统“-rwx rwx rwx” 的含义是什么？

答：前三位属主，中间三位同组，后三位其他用户访问权限

【注：书本中关于访问控制权限的相关章节中，确实没有出现这种类型的题目，也在这几年的 837 考研题目中不曾出现过，属于超纲内容。但我个人认为，了解 Unix、Linux、Windows 系统一些基础知识是相当必要的。尤其是其权限、认证、域控制等相关知识，出题人今后出题会不会将更多的知识点和实际相结合，进一步区分考生呢？】

3、填空题：IPSec 传输模式，（ ）数据可受数据加密保护。

答：传输层及上层数据报文（载荷）

【注：见书安全协议一章相关知识点】

4、填空题：PKI 系统中，证书公布使用的协议是（ ）

答：LDAP（轻量目录访问协议）

【注：见书 P66 页】

5、填空题：RSA 建立的理论基础是（ ）

答：大整数因子分解问题

【注：见书 P35 页，RSA 是考察的重点，请务必全部掌握，不可缺漏。需要掌握其概念，所属密钥体制，性能特点、应用范围、计算过程等等，这些内容放在后面提高部分。】

6、填空题：充分发挥 DES 和 RSA 两种密码体制的有点，解决密钥传送过程中的安全问题的技术是（ ）的（ ）

答：SET、电子信封

【注：电子信封技术解决对称密钥更新问题】

7、填空题：在 IPsec 中，（ ）是两个通信实体经过协调建立起来的一种协定，保护数据包安全，密钥算法密钥等信息。

答：SA（安全关联）

【注：安全协议显然是教材与考察的重点，其中的相关安全组成部分需要理解他们的作用与运作原理，做到见名知意，由作用反推名词】

8、填空题：计算机病毒的特征（ ）（ ）（ ）（ ）（ ）（ ）

答：传染性、潜伏性、破坏性、触发性、非授权性、寄生性

【注：基础知识，记忆即可。如果有能力，将这些特性与教材中举例的 CIH 病毒、尼姆达病毒、灰鸽子木马的相关病毒特点对应起来记忆。】

9、填空题：木马植入方式（ ）和（ ）

答：被动植入、手动植入

10、（1）填空题：木马隐藏通信的方法（ ）和（ ）（2）已知某木马代理能够连接外网木马远程控制端以逃避防火墙限制，则该技术是（ ）

答：（1）端口复用、反弹端口（2）反弹端口

【注：木马的隐蔽技术很有其特点，特别是隐藏通信技术，其原理也是需要掌握的，此处由于是填空题，将其归纳在基础知识中】

11、简答题：SSL 协议提供哪几种服务？

答：（1）保密通信服务（2）点对点身份认证服务（3）维护数据完整性服务

【注：这道题只做补充，考试不会这么出题，问题过于简单套路。此处作为基础题目目的是为了加深信息安全体系中安全控制和安全服务这两个重要概念。】

12、填空题：多个防火墙存在的网络环境中，每个连接两个防火墙的计算机或者网络都是（ ）

答：DMZ

【注：简单题，注意概念定义】

13、填空题：入侵检测 CIDE 模型中，（ ）的目的是从计算机环境中获取时间，并向系统其他部分提供。

答：事件产生器

【注：需要十分清楚入侵检测模型的几个组成部分，分别实现什么功能。同样，入侵检测的 IDES 模型也要做相应的复习。】

14、填空题：某病毒通过 RPCcom 缓冲区溢出漏洞进行传播，病毒运行后在 %system% 文件夹下生成自身拷贝，添加注册表选项，使自身能够开机自动运行，这种病毒类型是（ ）

答：蠕虫病毒

【注：这道题目很容易认为是木马病毒，因为有释放文件，修改注册表，开机自启动这些过程，与木马病毒的工作原理十分类似。但要注意各个类型的病毒的传播方式的不同，题目开头就说了是使用缓冲区溢出的漏洞进行传播，是蠕虫病毒传播的特征。而木马病毒的传播主要分为手动植入和被动植入，主要通过电子邮件附件，挂马网页、捆绑恶意软件等方式。

这道题目看似是使用教材外的特殊事例，实际上考察的是对三种传统病毒特点的掌握。考生需要对三种传统病毒的传播特点、工作原理形成一个较为鲜明的区分，考试肯定不会要求你默写出这些病毒的工作原理，但可能会要求你由特点选取相应类别，甚至要求你设计一种攻击工具，满足某些要求，达到某些目的，实际上就是考察你对这些知识点的掌握。】

15、填空题：SSL 握手可分为四个阶段，分别是（ ）、（ ）、（ ）和（ ）

答：建立安全能力、服务器认证密钥交换、客户端认证密钥交换、结束

【注：作为填空题，这部分较为简单，记忆即可。】

16、通常通过（ ）的方式实现访问控制

答：认证

17、单密钥体制下，对明文加密的处理类型是（ ）、（ ）

答：序列密码（流密码）、分组密码

【注：进一步要掌握两种加密模式的区别。】

18、公钥密码系统主要应用于（ ）、（ ）、（ ）方面

答：数字签名、密钥交换、通信保密

【注：要清楚公钥密码体制的应用范围，适用场景。这道题目没在初试中出现，反而在复试的面试第四轮出现，题目是：请你举例一下公钥密码的应用场景有哪些？应用过程是什么？】

19、Kerberos 由（ ）和（ ）组成

答：AS（认证服务器）TGS（票据授予服务器）

【注：教材花费很多篇幅讲解 Kerberos 相关知识，特别是认证过程的三个阶段和组成部分，要清楚三个阶段的目的是什么。考试不太可能考每个阶段里面的细节步骤，只需要清楚知道各个阶段的目的。举一反三，如果考试中题目让你设计类似的身份认证系统，你可以依葫芦画瓢设计（记忆）出来。例如：请你设计一个单点登录系统，满足单一地点登录。】

20、AS 负责（ ）功能，TGS 负责（ ）功能

答：签发访问 TGS 的票据，签发访问其他应用服务器票据

【注：同上题】